



ISC 互联网安全大会



360 互联网安全中心

构建以密钥沙箱为核心的安全应用环境

张凡 360企业安全集团移动安全资深专家

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)



ISC 互联网安全大会



360 互联网安全中心

目录

智能终端/IOT设备应用程序敏感信息
的保护需求分析

软件实现的密码模块（密钥沙箱）
安全实践

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

智能终端/IOT设备应用程序敏感信息的保护需求分析



ISC 互联网安全大会



360 互联网安全中心

安全挑战与安全需求

智能终端：应用程序运行在可变的运行环境中，运行环境无法提供足够的安全防护，甚至运行环境本身包含恶意代码。

IOT设备：应用程序运行在可变或相对固定的运行环境中，设备本身物理安全没有保证，设备固件有可能被替换和篡改。

安全解决方案的基础

应用程序需要一个可信和安全的密码模块存储敏感数据，运行敏感数据处理代码，并得出可信的结果。

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

智能终端/IOT设备应用程序敏感信息的保护需求分析



ISC 互联网安全大会



360 互联网安全中心

密码模块的设计与实现

设备内置硬件SE（系统级）

设备支持TEE，并加载对应TEE应用（系统级）

软件实现的密码模块（应用级）

应用级软件密码模块的现实意义

应用级软件密码模块可以为普通的设备 and 应用提供类似硬件SE的安全防护功能

应用级软件密码模块适配性强，可集成进任何应用，使应用可以在较高的安全起点上进行业务逻辑开发。

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

智能终端/IOT设备应用程序敏感信息的保护需求分析



ISC 互联网安全大会



360 互联网安全中心

软件密码模块必须具备的有别于硬件SE安全特性

与云端安全管理中心配合，作为一个整体为应用程序提供安全服务

运行时防护（代码，数据一致性检测，最少的环境依赖，运行时环境绑定，防动态调试）

代码混淆，防静态分析

密钥沙箱是360企业安全对软件密码模块的理解与实现

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360 互联网安全中心

软件实现的密码模块（密钥沙箱）安全实践

密钥沙箱功能设计

密钥沙箱安全设计

密钥沙箱应用场景

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

密钥沙箱在《公钥密码基础设施应用技术体系框架》中的位置



密钥沙箱为应用提供的功能



ISC 互联网安全大会



360 互联网安全中心

数据接口：GM/T 0019-2012 通用密码服务接口规范

环境类函数：初始化环境/清除环境/版本信息/用户登录/修改/注销登录

证书类函数（用户权限）：获取CA证书/用户证书操作/CRL查询...

密码运算类函数：base64/HASH/RSA/ECC/会话密钥协商/对称加解密

消息类函数：PKCS#7数字信封/签名/摘要，SM2数字信封/签名/摘要，...

控制接口：仅对接安全管理中心（专有）

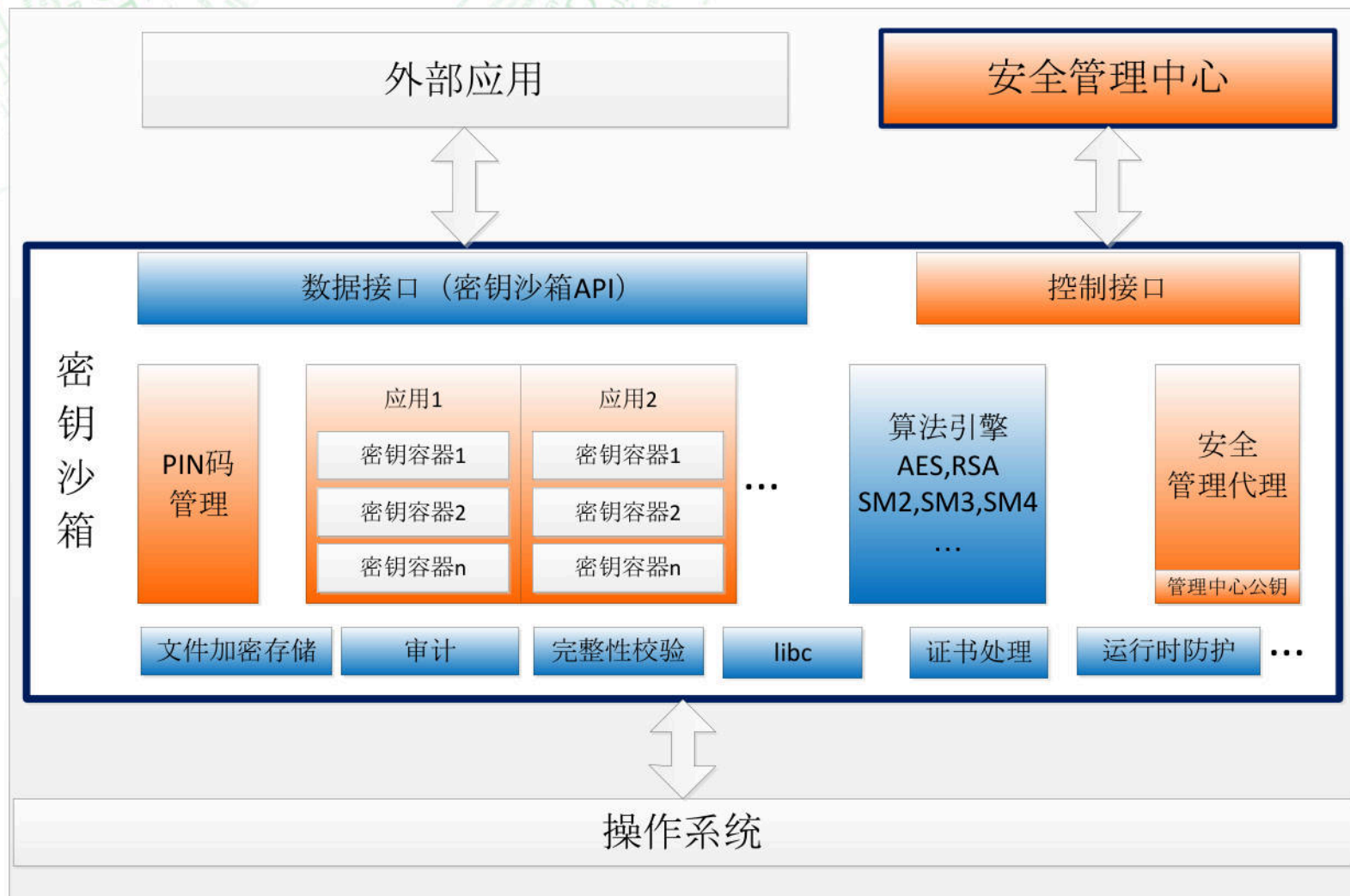
证书类函数（管理员权限）：CA证书及根证书添加删除/添加CRL...

专有信令：云端PIN码验证/证书信息同步/配置下发/安全管理...

ZERO TRUST SECURITY



前端密钥沙箱组成



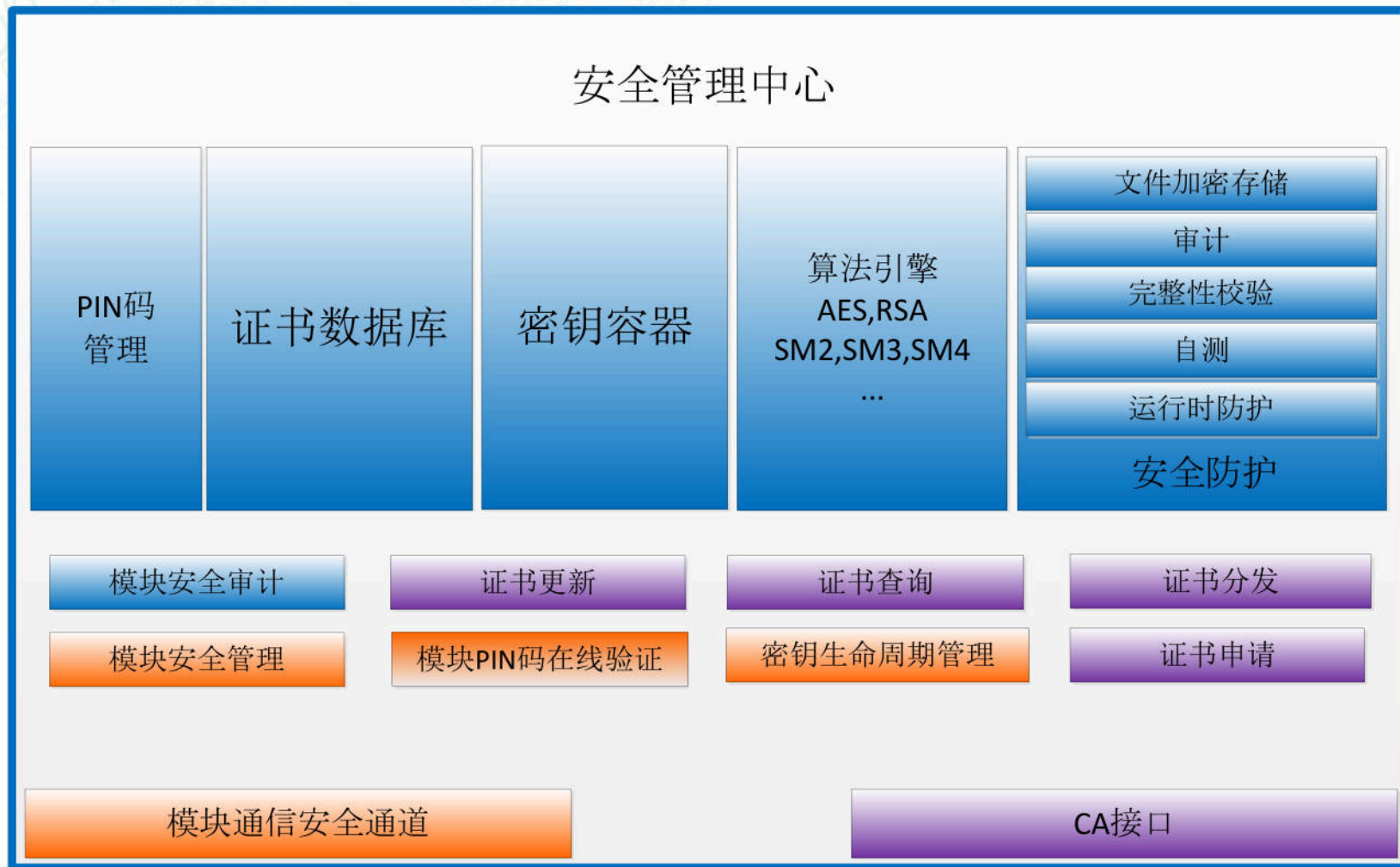
密钥沙箱敏感数据，身份鉴别，安全管理中心相关

密钥沙箱基础功能部件

安全管理中心组成



安全管理中心



密钥沙箱基础功能部件

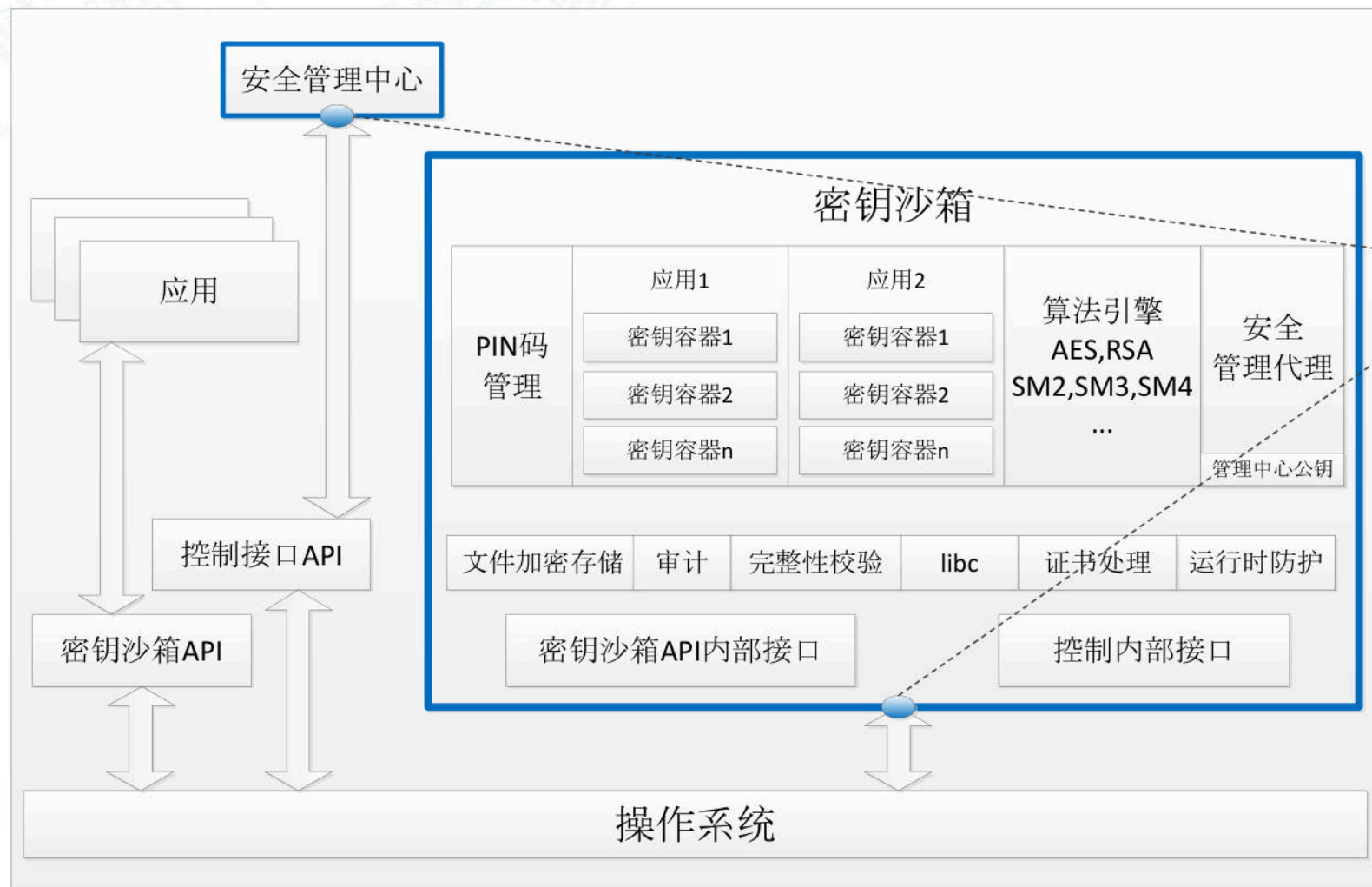
与密钥沙箱一体化设计
核心组件

CA代理, 对接CA系统
证书申请, 分发...

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

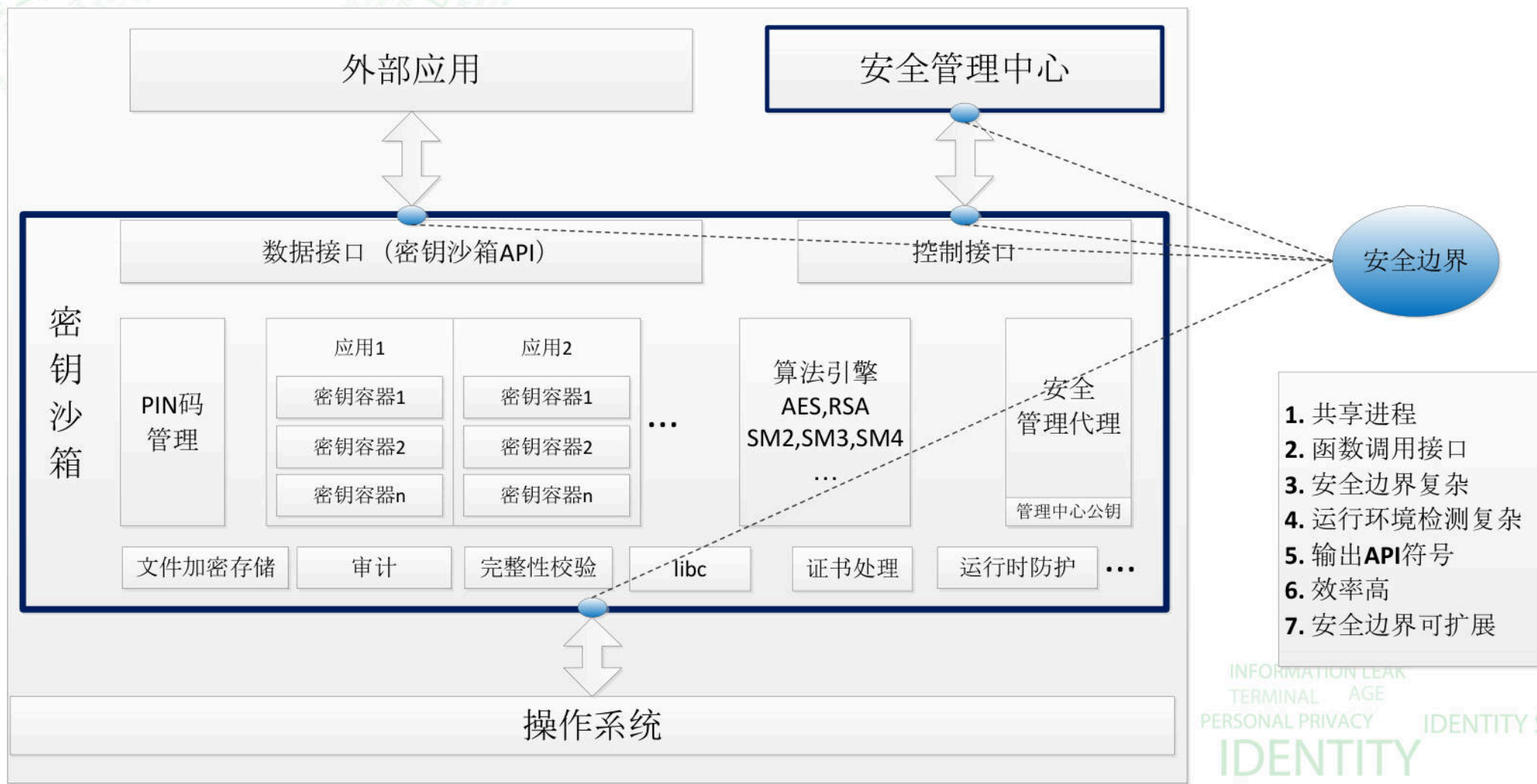
密钥沙箱安全边界——独立进程模式



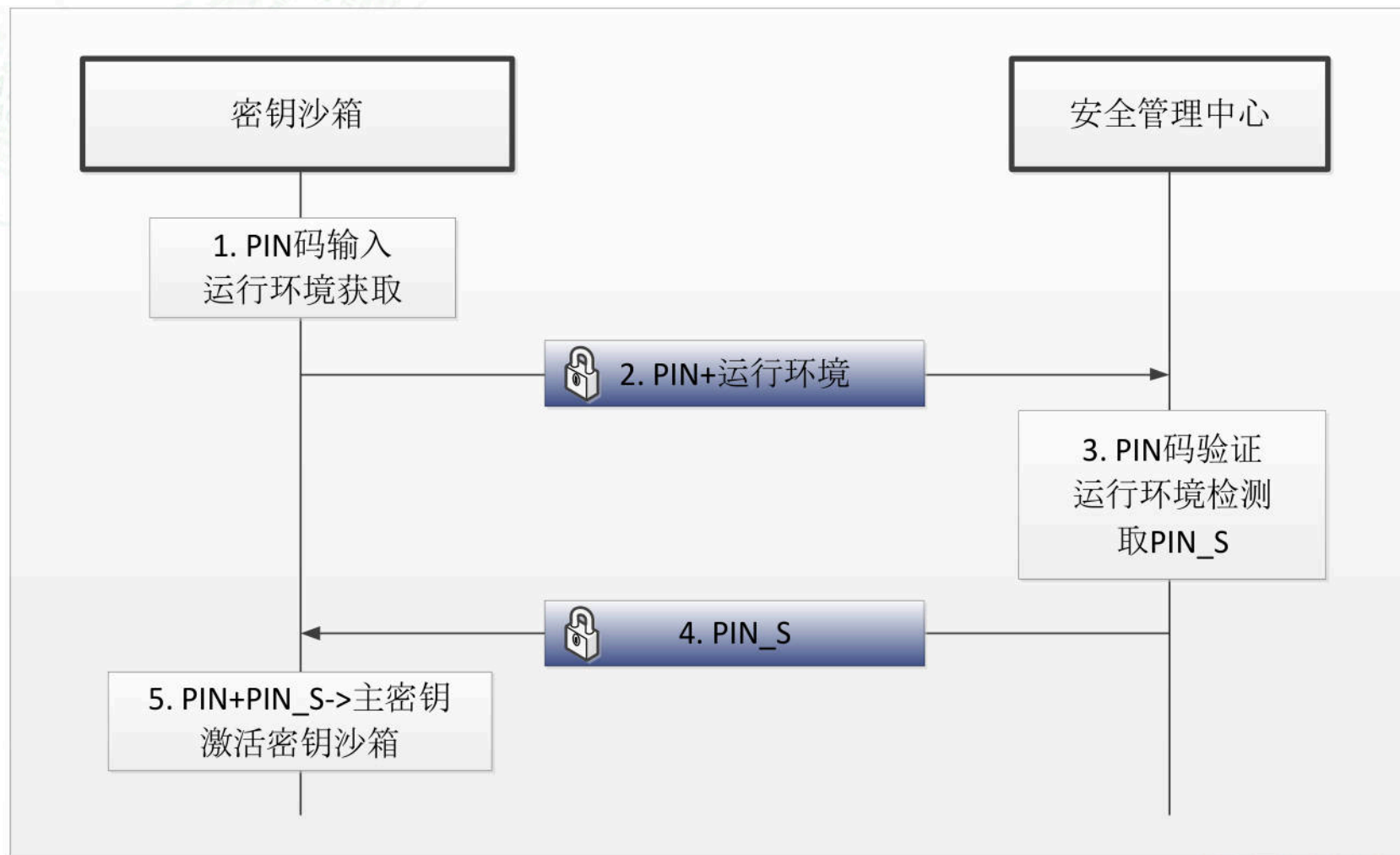
安全边界

1. 独立进程
2. 跨进程通信接口
3. 安全边界单一
4. 运行环境检测易
5. 几乎无输出符号
6. 安全性高
7. 跨进程效率有影响

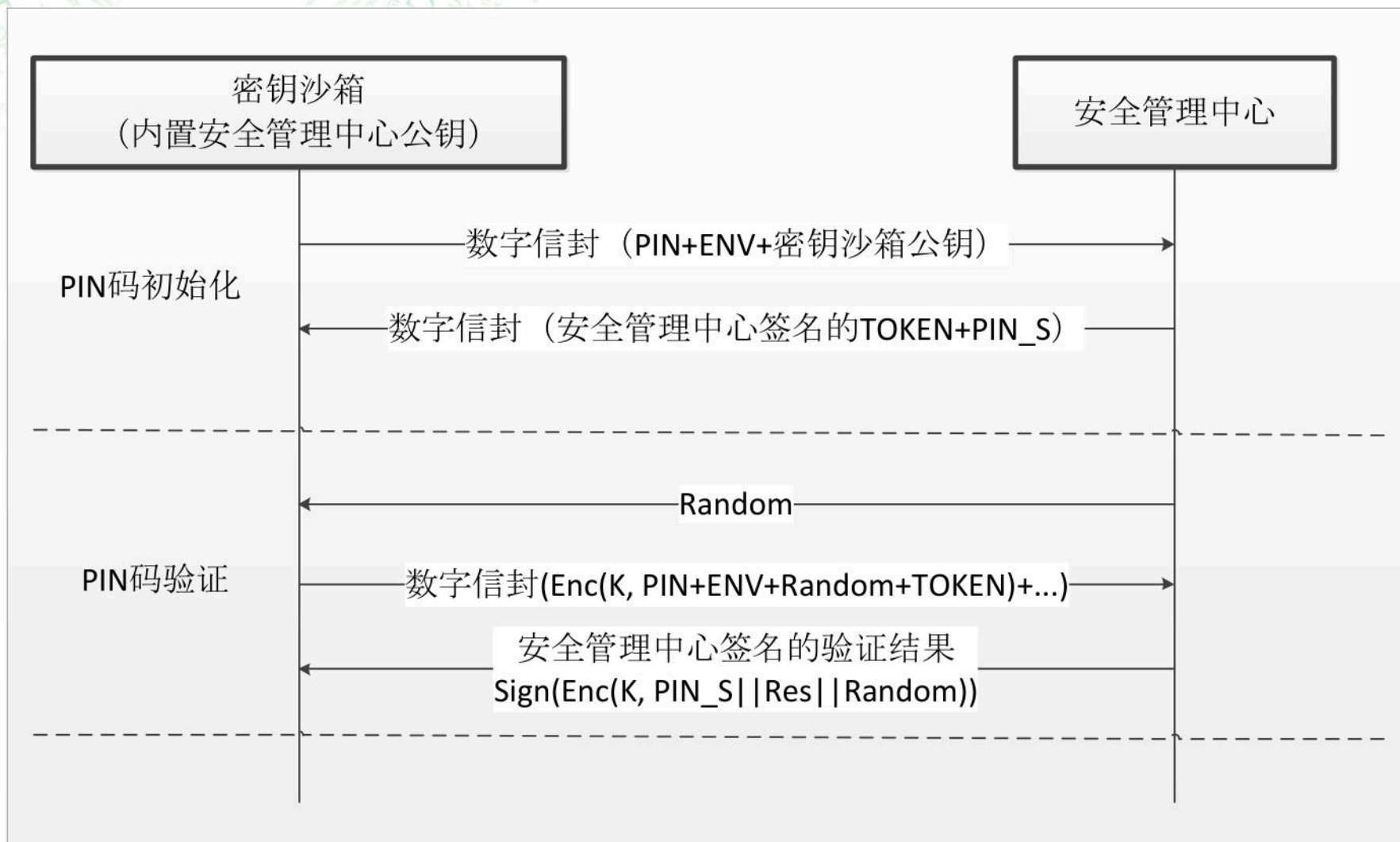
密钥沙箱安全边界——嵌入模式



密钥沙箱，安全管理中心一体化设计



密钥沙箱云端PIN码验证流程



主密钥防护机制

代码混淆（代码复杂程度增加30~200倍可调）

运行时防护（完整性检测，运行环境检测，防动态分析...）



与安全管理中心结合，为应用提供一体化的安全服务

密钥沙箱云端PIN码验证，并拥有实际PIN码的一部分，安全管理中心会根据前端返回的运行环境信息综合判定密钥沙箱用户身份。

前端密钥沙箱的用户身份判断逻辑在安全管理中心，运行环境、设备绑定可以做到很强，很完备。

前端密钥沙箱的任何一次PIN码尝试及其运行环境安全管理中心都记录在案，可以实时和后台分析锁定可疑设备及行为。

运行时防护，代码混淆：缓解动静态分析攻击

运行环境，设备，应用绑定

代码，数据一致性检测

防动态调试

代码自包含，除操作系统外无依赖

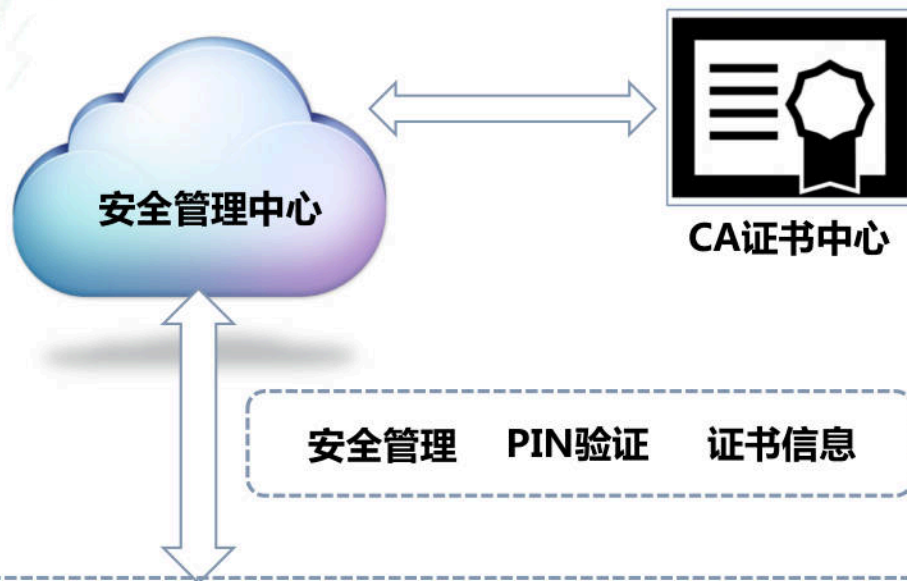
代码混淆，缓解静态分析攻击

密钥沙箱使应用可以在较高的安全起点上进行业务逻辑的开发。

使用场景

密钥沙箱

以软件实现传统U盾（SD加密卡）功能的密码模块，不依赖硬件密码芯片，用软件实现敏感信息保护、文件加解密、签名验签、证书导入、解析等功能。



邮件、文件传送类应用



提供端到端安全
加密能力

手机银行、财务应用



提供密钥安全存储、
数字签名能力

需要证书认证的应用



提供证书安全存储、
解析能力，可与CA
结合

物联网终端



车联网终端



安防监控终端



智能家居终端



工业智能终端

.....

提供密钥安全存储、身份认证、数字签名等能力



ISC 互联网安全大会



360 互联网安全中心

谢谢！

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)